

LECTURE NOTES

Information System Security

Week 2

Malicious Attacks, Threats, and Vulnerabilities

LEARNING OUTCOMES

LO2. Explain IS security item and aspect

OUTLINE MATERI (Sub-Topic):

1. Malicious activity
2. What are we are trying to protect, whom are you trying to catch
3. Attack tools
4. Security breach
5. What are vulnerabilities and threats, and malicious attack
6. The countermeasure

ISI MATERI

Anda mungkin pernah melihat kisah di berita, atau iklan lucu di TV, atau membaca berita utama tentang serangan siber. Contoh kasusnya seperti: Baru-baru ini, pihak berwajib menangkap dan memenjarakan seorang mahasiswa selama 20 tahun karena meretas akun email calon wakil presiden Amerika Serikat. Dalam insiden serupa, perusahaan *retail* pakaian TJX Companies mengaku ceroboh dalam membiarkan pencurian data jutaan nomor kartu pembayaran pelanggannya. Selain itu, dalam iklan *prime-time* yang lucu, seorang karyawan yang tidak tahu apa-apa membuka akses untuk penyerangan virus setingkat perusahaan dengan mengklik email "tidak berbahaya". Di mana-mana di sekitar Anda, Anda bisa menemukan contoh serangan berbahaya yang dihadapi ahli keamanan setiap hari. Meskipun serangan ini menarik perhatian redaksi berita dan publik, kebanyakan korban serangan siber tidak mempublikasikan insiden yang menimpa mereka sama sekali. Setiap hari, sistem di seluruh dunia berada di bawah ancaman. Di kebanyakan kasus, satu-satunya orang yang tahu tentang serangan-serangan ini adalah ahli keamanan dan personel TI.

Ahli keamanan bertanggung jawab untuk melindungi sistem mereka dari ancaman dan juga bertanggung jawab menangani saat terjadinya serangan berbahaya. Salah satu cara yang paling efektif untuk melindungi sistem komputer adalah dengan memastikan bahwa adanya kerentanan.

What Are You Trying to Protect ?

Inti dari masalah security adalah karena ada sesuatu yang ingin kita lindungi. Kita ingin melindungi aset dari perusahaan. Aset adalah segala sesuatu yang memiliki nilai. Meskipun semua benda memiliki nilai, aset biasanya mengacu kepada benda yang memiliki nilai yang signifikan. Contohnya adalah

- Infrastruktur IT dan network
- Intellectual property
- Finance dan data financial
- Reputasi
- Service availability

Perangkat keras dan perangkat lunak yang terkena serangan berbahaya seperti *Trojan horse* atau *worm*, mengharuskan perusahaan mengeluarkan waktu dan biaya untuk memperbaiki atau mengganti. Serangan berbahaya pada perangkat keras dan perangkat lunak juga dapat menyebabkan masalah yang bisa menyebar lebih luas. Masalah-masalah ini dapat mencakup hilangnya data penting atau pencurian informasi keuangan atau kekayaan intelektual. Aset infrastruktur jaringan dan TI yang tidak terlindungi bisa menjadi celah terluas bagi penyerang dan penjahat dunia maya untuk mengakses sumber daya yang sensitif. Kemudahan akses membuat aset-aset yang terhubung dengan Internet merupakan titik serangan pertama yang paling umum. Itu artinya aset tersebut seharusnya menjadi garis pertahanan pertama yang wajib dilindungi.

Inti masalah dari sudut pandang keamanan TI adalah melindungi pencurian properti intelektual dan mencegah terungkapnya data tersebut ke pesaing atau publik. Pencurian property intelektual dapat menghilangkan keunggulan organisasi dalam berkompetisi. Bayangkan sebuah perusahaan bernama Alpha Drug Company menginvestasikan \$2 miliar untuk mengembangkan obat resep baru, dengan harapan bahwa itu akan menghasilkan \$10 miliar ketika obat itu diedarkan ke publik. Sekarang bayangkan perusahaan Alpha Drug yang akan mengedarkan obatnya ke pasar, Namun ada perusahaan Beta Drug memperoleh formula dari perusahaan Alpha Drug dan meluncurkan versinya sendiri ke pasar. Perusahaan Alpha Drug akan kehilangan semua uang yang diinvestasikan dalam riset dan pengembangan, dan sebagian besar pendapatan yang diperkirakan dengan diedarkannya obat baru. Melindungi kekayaan intelektual adalah pertimbangan serius untuk semua ahli keamanan TI.

Kehilangan aset keuangan karena serangan jahat adalah perkiraan skenario terburuk untuk semua organisasi. Tidak hanya mewakili kerugian fisik yang signifikan, tetapi juga berdampak pada kerugian reputasi dan citra merk perusahaan secara jangka panjang *Downtime* yang tidak disengaja biasanya disebabkan oleh kesalahan teknis, kesalahan manusia, atau karena penyerangan. Kesalahan teknis dan kesalahan manusia adalah penyebab paling umum untuk kesalahan *downtime* yang tidak disengaja Meskipun waktu henti yang disebabkan oleh serangan berbahaya jarang terjadi, penelitian menunjukkan bahwa penyerangan berkembang semakin pesat. Serangan berbahaya dapat terjadi dan menyebabkan *downtime* di semua tujuh domain infrastruktur TI, tetapi Anda lebih mungkin melihatnya di sisi pengguna, *workstation*, domain LAN, dan WAN

Salah satu hal terpenting yang coba dilindungi oleh para ahli keamanan informasi adalah reputasi dan citra merek organisasi mereka. Perusahaan yang mengalami masalah

pelanggaran keamanan dan serangan jahat yang mengekspos aset apa pun kemungkinan akan menghadapi dampak konsekuensi yang negatif di mata publik. Misalnya, pelanggaran keamanan yang memungkinkan penyerang untuk mencuri data kartu kredit pelanggan dan mendistribusikannya secara internasional akan sangat merusak reputasi dan citra merek perusahaan tersebut. Bahkan jika responnya cepat dan memecahkan masalah secara efektif, persepsi negatif publik terhadap perusahaan dan mereknya bisa bertahan untuk jangka panjang. Di antara konsekuensi lain, ini dapat menyebabkan turunnya pendapatan organisasi.

Whom Are You Trying to Catch?

Umumnya kita akan menyebutkan hacker. Hacker umumnya di deskripsikan sebagai seseorang yang masuk kedalam sistem komputer tanpa ijin. Dalam komunitas komputer, hacker secara umum mendeskripsikan seorang programmer yang pandai, atau technical expert yang menyukai dan mempelajari sistem komputer. Karena dua deskripsi itulah kadang-kadang istilah hacker menimbulkan kontroversi, sehingga muncul beberapa istilah berikut ini

- Black-hat hackers. seorang black hat hackers membobol sistem keamanan karena menyukai tantangan dan membuktikan kemampuannya.
- White-hat hackers. Atau sering juga disebut sebagai ethical hacker. Adalah seorang network profesional atau information security profesional yang menggunakan beragam metode dan cara untuk membobol suatu sistem agar sistem tersebut bisa semakin disempurnakan
- Gray-hat hackers. Adalah hacker dengan kemampuan rata-rata saja yang berkeinginan menjadi black hat hacker

Disamping ketiga istilah diatas, ada juga yang disebut cracker. Yakni seseorang yang dengan niat yang kurang baik, menerobos celah keamanan dengan tujuan uang. Dan yang lainnya adalah Script kiddie. Yaitu orang yang hanya memiliki skill sedikit, dan mencoba membobol celah keamanan dengan mengikuti petunjuk yang ada di dalam buku tanpa memahami secara penuh apa yang sedang dilakukan.

Attack tools

Untuk melindungi suatu sistem, tentunya akan lebih baik lagi jika kita memiliki pengetahuan mengenai alat-alat yang dapat digunakan untuk melakukan serangan terhadap sistem. Berikut ini adalah beberapa software yang bisa digunakan untuk menemukan celah keamanan

Vulnerability Scanners

Tools yang akan mengumpulkan informasi mengenai kelemahan umum sebuah sistem. Bekerja dengan cara mengirimkan pesan khusus ke sistem sasaran. Bagaimana cara sistem tersebut membalas pesan tersebut akan menunjukkan apakah sistem tersebut memiliki celah atau tidak

Port scanners

Port scanner memeriksa port apa sajakah yang di buka dalam sebuah sistem. Nomor port yang terbuka biasanya menunjukkan aplikasi apa saja yang berjalan dibalik sistem tersebut. Dengan begitu si penyerang akan mendapatkan gambaran aplikasi apa yang bisa di serang.

Sniffers

Adalah sebuah software yang menangkap data yang dikirimkan melalui jaringan. Dengan menangkap data yang melalui jaringan, terkadang bisa didapatkan informasi penting seperti username dan password.

Keylogger

Merupakan software atau hardware yang akan mencatat semua ketikan yang dilakukan user di keyboard. Catatan ini kemudian dikirimkan kepada si penyerang. Dalam catatan ini bisa ditemukan informasi penting seperti username dan password.

What is security breach ?

Segala kejadian yang menyebabkan dilanggarnya Availability, Integrity, dan Confidentiality dari sebuah sistem, disebut sebagai pelanggaran sebuah sistem. Sebuah pelanggaran sistem dapat mengakibatkan terganggunya sebuah sistem, atau kegagalan total sistem tersebut. Berikut ini adalah beberapa aktivitas yang dapat dikatakan sebagai pelanggaran sistem atau dapat menyebabkan pelanggaran sistem.

Denial of Service Attack

Serangan ini mengakibatkan user dari sistem menjadi tidak bisa menggunakan sistem karena beban sistem menjadi penuh karena sistem memproses hal-hal yang tidak penting. Ada dua jenis DoS:

Logic Attack. Biasanya menggunakan kelemahan software untuk membuat sistem menjadi crash atau menurunkan performance server secara signifikan.

Flooding Attack. Membebani server dengan mengirimkan request dalam jumlah yang sangat besar sehingga server menjadi tidak sanggup lagi memproses request yang sebenarnya.

Salah satu cara untuk mengatasi DoS adalah dengan menggunakan IDPS

Unacceptable web browsing behavior

Setiap perusahaan biasanya memiliki aturan dan kebijakan tersendiri mengenai apa saja yang boleh diakses oleh karyawannya melalui web browser. Unacceptable web browsing mendeskripsikan apa saja yang boleh dan tidak boleh dilakukan karyawan melalui web browsernya.

Wiretapping

Tindakan mendengarkan/menyadap jalur telepon atau jalur komunikasi lainnya. Dikatakan aktif jika penyerang melakukan perubahan terhadap data. Dikatakan pasif jika penyerang hanya mendengarkan saja, tanpa melakukan perubahan.

Spam

Spam adalah email atau pesan yang tidak diinginkan. Biasanya berisi pesan komersil. Spam bisa mengganggu karena akan memenuhi inbox penerima dengan pesan yang tidak penting, sehingga pesan yang benar-benar diperlukan menjadi lolos dari perhatian penerima.

Hoaxes

Hoax merupakan kabar yang tidak dapat dipastikan kebenarannya. Biasanya dikirimkan melalui email. Terkadang, hoax juga membawa malware dalam pesannya. Hoax bisa berbahaya jika mengarah kepada tindakan yang membuka celah keamanan. Salah satu situs yang mengklarifikasi mengenai hoax adalah snopes.com. melalui situs ini kita bisa mempelajari apakah pesan tersebut benar atau tidak.

What Are Vulnerabilities and Threats

Vulnerability adalah kecacatan atau kelemahan yang terdapat dalam sebuah sistem. Sedangkan threat adalah ancaman yang dapat menyebabkan kerusakan di sebuah sistem. Threat bisa menyebabkan kerusakan yang serius jika bertemu dengan vulnerability dalam sistem. Jika kerentanan ada dalam suatu sistem, maka ancaman pun juga mengintai. Ancaman apa pun terhadap kerentanan menciptakan risiko bahwa peristiwa negatif dapat terjadi. Anda tidak dapat menghilangkan ancaman, tetapi Anda dapat memberikan perlindungan dari kerentanan. Dengan begitu, meski ancaman tetap ada, kerentanan Anda takkan sampai dieksploitasi. Kunci untuk melindungi aset dari risiko serangan adalah untuk menghilangkan atau mengatasi kerentanan sebanyak mungkin

Ancaman dapat datang dari individu, sekelompok individu, atau organisasi. Ancaman terhadap perangkat komputasi dapat berupa tindakan apa pun, baik yang tidak disengaja atau berbahaya, yang dapat memiliki efek negatif pada aset dan sumber daya individu atau organisasi. Aset mungkin berbentuk perangkat keras, perangkat lunak, database, file, data, atau jaringan fisik itu sendiri. Ancaman sifatnya signifikan jika dilihat dari sudut pandang keamanan. Tujuan dari keamanan komputer adalah untuk memberikan wawasan, metodologi, dan teknik yang menangani ancaman. Anda bisa mencapai tujuan ini dengan mengembangkan kebijakan yang membantu administrator sistem komputer dan jaringan, desainer, pengembang, dan pengguna menghindari karakteristik dan kelemahan sistem yang tidak diinginkan. Anda dapat mengidentifikasi ancaman dan memberi peringkat berdasarkan kepentingan dan dampaknya. Anda dapat menentukan peringkat ancaman berdasarkan kerugian finansial, reputasi negatif yang tercipta, kewajiban moneter, atau seberapa sering ancaman tersebut mungkin terjadi. Setiap organisasi dapat memberi peringkat ancaman lebih tinggi atau lebih rendah dibandingkan organisasi lain tergantung kepentingan organisasi masing-masing. Peringkat sebuah ancaman sangat bergantung pada dampak yang bisa ditimbulkan.

Menggunakan mesin pencari favoritnya, penyerang dapat menemukan instruksi yang tepat untuk menyusup ke hampir semua lingkungan protokol, sistem operasi, aplikasi, perangkat, atau perangkat keras. Untuk alasan inilah, Anda harus memantau semua ancaman dengan sangat cermat. Anda tak pernah tahu di mana satu serangan selanjutnya akan datang. Mungkin serangan tersebut bisa datang dari penjahat dunia maya profesional atau seseorang di dalam perusahaan Anda sendiri. Cara paling aman adalah memantau semua target ancaman secara

konstan dan hati-hati. Langkah pertama dalam mengembangkan rencana pemantauan adalah mengidentifikasi di mana dalam tujuh domain ancaman infrastruktur TI mungkin terjadi. Berikut ini adalah beberapa target yang umum ditemui dalam sebuah sistem.

DOMAIN	THREAT TARGET
User Domain	PCs, laptops, smartphones (BlackBerry, iPhone), personal digital assistants (PDAs), application software (productivity, Web browsing, etc.)
Workstation Domain	Administrative workstations, laptops, departmental workstations and servers, network and operating-system software
LAN Domain	File servers, print servers, e-mail servers, administration servers, database servers, wireless LAN servers (WLANs), hubs, repeaters, bridges
LAN-to-WAN Domain	HTTP servers, e-mail servers, terminal servers (FTP, etc.), IP routers, firewalls, hubs, repeaters
WAN Domain	IP routers, TCP/IP stacks and buffers, firewalls, gateways, switches
Remote Access Domain	Virtual private networks (VPNs), third-party e-mail redirect (i.e., RIM/BlackBerry), laptops with VPN software, SSL-VPN tunnels
System/Application Domain	Desktop operating systems, server and network operating systems, e-mail applications and servers, Enterprise Resource Planning (ERP) applications and systems, Web browsers

Table daftar sasaran ancaman

Ada tiga jenis threat yang mungkin dihadapi:

Denial or destruction threat

Tujuan dari ancaman ini adalah menyebabkan suatu resource tidak bisa digunakan. Ancaman ini dikatakan berhasil apabila user tidak dapat menggunakan aplikasi atau data yang diinginkannya.

Alteration threat

Ancaman ini melanggar integritas data. Serangan ini mengacaukan sistem dengan merubah data. Salah satu pencegahannya adalah dengan membuat backup rutin. Cara lainnya untuk mengetahui apakah telah terjadi perubahan adalah dengan melakukan ceksum.

Disclosure threat

Disclosure terjadi ketika user yang tidak berhak, mengakses data yang bersifat rahasia.

Tidak semua ancaman berbahaya. Meskipun beberapa ancaman mungkin sifatnya disengaja, sisanya bisa jadi tidak disengaja. Ancaman yang tidak disengaja mungkin termasuk kesalahan perangkat keras atau masalah perangkat lunak yang disebabkan oleh kurangnya kontrol. Hasil dari ancaman yang tidak disengaja bisa sama merusaknya dengan ancaman berbahaya. namun. Anda harus melakukan segala upaya untuk meminimalisir semua pelanggaran keamanan, baik yang berbahaya atau tidak disengaja. Tujuan utamanya adalah untuk melindungi jaringan dan sistem komputer dari serangan apapun. dan untuk mencegah pencurian, kehancuran, dan hilangnya aset individu atau organisasi.

What is malicious attack?

Sebuah serangan yang ditujukan kepada sebuah sistem, dengan memanfaatkan celah keamanan yang terdapat didalam sistem tersebut

Secara umum ada empat kategori serangan. Sebuah serangan bisa terdiri dari salah satu, gabungan atau seluruh kategori ini:

- **Fabrication.** Menciptakan sebuah pengalihan untuk mengelabui user yang kurang paham
- **Interception.** Menyadap sebuah transmisi atau mengalihkan transmisi tersebut untuk hal yang terotorisasi.
- **Interruptions.** Memutus jalur komunikasi dan menghalangi jalannya komunikasi.
- **Modification.** Merubah data yang terdapat didalam sebuah transmisi.

Beberapa contoh malicious attack:

- Brute-force attack
- Dictionary threat
- Address spoofing
- Hijacking
- Man-in-the-middle attack
- Social engineering

Tidak semua perangkat lunak melakukan tugas yang bermanfaat. Beberapa perangkat lunak menyusup ke satu atau beberapa komputer dan berfungsi untuk mengikuti instruksi penyerang. Instruksi ini dapat menyebabkan kerusakan, meningkatkan hak keamanan,

membocorkan data pribadi, atau bahkan memodifikasi atau menghapus data. Jenis perangkat lunak ini adalah perangkat lunak yang berbahaya, atau sering disebut *malware*.

Tujuan dari *malware* adalah untuk merusak atau mengganggu sebuah sistem. Efek *malware* bisa dalam bentuk memperlambat PC, menyebabkan *crash*, hingga pencurian nomor kartu kredit, dan banyak lagi. Cukup berselancar di Internet, membaca email, atau mengunduh musik atau file lainnya bisa menginfeksi komputer pribadi dengan *malware*-biasanya tanpa sepengetahuan pengguna. *Malware* ada dalam dua kategori utama: menginfeksi program dan menyembunyikan program. Program yang menginfeksi secara aktif mencoba untuk menyalin *malware* ke komputer lain. Tujuan utama *malware* adalah untuk melaksanakan instruksi penyerang pada target-target baru.

Malicious software adalah sebuah software yang menyusup kedalam sistem untuk melakukan instruksi khusus, dan menyebabkan kerusakan di dalam sistem tersebut. Beberapa contoh dari malicious software adalah:

- Virus
- Worm
- Trojan
- Spyware
- Rootkit

Virus

Virus komputer adalah program perangkat lunak yang menempel atau menyalin dirinya sendiri ke dalam program lain di komputer. Tujuan dari virus adalah untuk mengelabui komputer mengikuti instruksi yang tidak sejalan dengan pengembang program asli. Pengguna menyalin file yang terinfeksi dari komputer lain di jaringan, dari *flash drive*, atau dari layanan daring. Atau, pengguna dapat membawa virus dari rumah dan menyebarkannya di perangkat komputer portabel mereka, yang memiliki akses ke Internet dan layanan jaringan lainnya. Virus komputer bertindak dengan cara yang mirip dengan virus biologis. Virus menginfeksi sebuah *host program*, dan dapat menyebabkan *host program* tersebut mereplikasi dirinya ke komputer lain. Virus tidak dapat hidup tanpa host, dan dapat menyebar dari host satu ke host lain dengan cara menular.

Worm

Worm adalah program mandiri yang mereplikasi dan mengirimkan salinan dirinya ke komputer lain, umumnya melalui jaringan. Tujuan worm mungkin hanya untuk mengurangi ketersediaan dengan menggunakan *bandwidth* jaringan, atau mungkin mengambil tindakan jahat lainnya. Perbedaan utama antara virus dan worm adalah bahwa worm tidak membutuhkan *host program* untuk menginfeksi. Worm adalah program yang berdiri sendiri.

What are countermeasure?

Tidak ada cara yang sederhana untuk melindungi sistem dari serangan orang-orang yang tidak berhak. Untuk melindungi sistem dari serangan, kita perlu fokus terhadap kelemahan sistem yang mungkin muncul, mencegah serangan, dan memperbaiki dampak yang terjadi akibat serangan.

Meskipun penyerang dan penyusup yang cerdas terus menemukan metode baru untuk menyerang sumber daya komputer dan jaringan, banyak cara penyerangan yang terkenal dan dapat dikalahkan dengan berbagai alat keamanan yang tersedia. Strategi terbaik adalah mengidentifikasi kerentanan dan mengurangi kerentanan tersebut untuk menghindari serangan. Menghindari serangan harus menjadi prioritas utama. Meski begitu, beberapa serangan akan berhasil. Respon Anda terhadap serangan harus sama agresif, proaktif, dan reaktifnya dengan serangan itu diri. Anda dapat menanggapi serangan dengan mengembangkan rencana untuk memulihkan komputer dan sumber daya jaringan dengan cepat jika diserang, menutup celah di pertahanan organisasi Anda, dan memperoleh bukti untuk penuntutan pelanggar. Tentu saja, Anda harus belajar dari suatu serangan untuk melindungi jaringan dari serangan serupa. Berikut ini adalah beberapa langkah umum yang dapat dilakukan ketika menghadapi serangan keamanan:

- Melakukan edukasi terhadap user untuk mencegah user menginstall malware
- Menerbitkan pemberitahuan mengenai malware
- Jangan pernah menerima file dari komputer yang tidak dikenal atau tidak terpercaya, kecuali komputer memiliki software anti-malware
- Test software baru pada komputer yang terisolasi dari jaringan yang sebenarnya.
- Install software anti-malware, dan pastikan selalu terupdate dengan baik.
- Menggunakan proses logon dan autentikasi yang aman.

Beberapa sumber lain yang bisa kita pelajari untuk mendapatkan informasi mengenai malware adalah

- National Cyber Security Alliance (NCSA) <http://www.staysafeonline.org>
- Computer Security institute (CSI) <http://gocsi.com>
- United states computer emergency readiness team (US-CERT) <http://us-cert.gov>

KESIMPULAN

Inti dari masalah security adalah karena ada sesuatu yang ingin kita lindungi. Kita ingin melindungi aset dari perusahaan. Aset adalah segala sesuatu yang memiliki nilai

Cracker yaitu seseorang yang dengan niat yang kurang baik, menerobos celah keamanan dengan tujuan uang. Dan yang lainnya adalah Script kiddie. Yaitu orang yang hanya memiliki skill sedikit, dan mencoba membobol celah keamanan dengan mengikuti petunjuk yang ada di dalam buku tanpa memahami secara penuh apa yang sedang dilakukan.

Beberapa software yang bisa digunakan untuk menemukan celah keamanan

- Vulnerability Scanners
- Port scanners
- Sniffers
- Keylogger

Segala kejadian yang menyebabkan dilanggarnya Availability, Integrity, dan Confidentiality dari sebuah sistem, disebut sebagai pelanggaran sebuah sistem

Ada tiga jenis threat yang mungkin dihadapi

- Denial or destruction threat
- Alteration threat
- Disclosure threat

DAFTAR PUSTAKA

1. Kim, David. And Michael G. Solomon,(2012), **Fundamentals of Information System Security**, Jones & Bartlett Learning, Sudbury